

Validation des Défenses

Objectifs :

- Passer d'une sécurité théorique (implémentation) à une sécurité vérifiée (validation).
- Simuler des attaques réseaux et locales pour valider l'étanchéité du modèle Zero Trust sur Windows et Linux.
- Mesurer la réduction de la surface d'attaque via des outils d'audit.
- Analyser la remontée d'alertes dans le SIEM (Boucle de détection SOC).

1. Le concept de Validation Continue (Purple Teaming)

En architecture de sécurité, l'implémentation de règles (GPO, Pare-feu, AppLocker, UFW) n'est que la première étape. L'ANSSI et les référentiels modernes exigent une validation technique par la preuve.

1.1 Limites de l'audit déclaratif

Vérifier qu'une stratégie est "Activée" dans l'interface graphique ou via un fichier de configuration ne garantit pas que le système est protégé. Des conflits de registre, des erreurs d'héritage d'Unité d'Organisation (OU), ou des configurations matérielles incompatibles peuvent rendre la politique inopérante.

1.2 L'approche "Purple Team" Croisée

L'exercice de synthèse réunit la posture offensive (Red Team) et défensive (Blue Team). L'objectif est d'utiliser les systèmes de manière croisée : la machine Linux cible le serveur Windows pour valider le durcissement AD/Système, puis la machine Windows cible le Bastion Linux pour valider le filtrage SSSD/Réseau.

2. Validation des vecteurs d'attaque réseau

La première phase du Crash-Test consiste à valider la micro-segmentation, l'isolation et la cryptographie sur les deux environnements.

2.1 Audit de surface (Scan de ports et Filtrage)

Un attaquant commence systématiquement par une phase de reconnaissance pour identifier les services exposés.

- **Cible Windows (IPsec) :** Un scan de ports (135, 445, 3389, 5985) doit retourner un état **filtered**. Le pare-feu Windows, configuré pour exiger une authentification IPsec (IKE/Kerberos), rejette silencieusement les requêtes provenant d'une machine non membre du domaine.
- **Cible Linux (UFW) :** Un test de connexion sur des ports standards (ex: 80, 443) doit échouer. Le pare-feu UFW en politique "Default Deny" détruit le trafic entrant non légitime, n'autorisant que le canal d'administration (SSH/22).

2.2 Validation de l'hygiène cryptographique (Downgrade Attack)

L'attaquant tente de forcer le client à utiliser un protocole obsolète ou un chiffrement faible (ex: 3DES, RC4).

- **Validation :** Les serveurs (Schannel sous Windows, OpenSSH sous Linux) doivent rejeter la négociation (Handshake) instantanément. Le client retourne une erreur indiquant l'absence d'algorithmes d'échange de clés (KEX) ou de chiffrements communs, prouvant la robustesse du canal.

2.3 Tentative de Mouvement Latéral (Pass-the-Hash)

Si un accès réseau est obtenu, l'attaquant tente de s'authentifier via des empreintes volées ou en ciblant des mots de passe locaux.

- **Validation LAPS :** L'impossibilité d'utiliser le compte administrateur local par défaut. Le mot de passe est unique, complexe et stocké de manière chiffrée dans l'Active Directory (attribut **msLAPS-EncryptedPassword**), le rendant illisible pour un compte compromis.

3. Validation des vecteurs d'attaque locaux et d'identité

La seconde phase simule un attaquant ayant réussi à obtenir un accès initial avec un compte standard.

3.1 Test de la politique de Liste Blanche (Windows)

La simulation consiste à déposer un binaire exécutable non autorisé dans un répertoire inscriptible (ex: **C:\Windows\Temp**).

- **Validation AppLocker/WDAC :** Le noyau Windows retourne un code d'erreur (Access Denied) lors de la tentative d'exécution.
- **Validation JEA / PowerShell :** L'ouverture d'un script non signé force l'interpréteur PowerShell à basculer en Mode de Langage Contraint (CLM), bloquant l'accès aux API

Win32 et à la réflexion .NET.

3.2 Test du Modèle en Tiers et de l'Identité (Linux)

L'attaquant tente d'ouvrir une session d'administration SSH sur le Bastion Linux en utilisant un compte Active Directory standard valide.

- **Validation SSSD/PAM** : La connexion est rejetée (**Permission denied**). SSSD valide l'existence du compte, mais le module PAM bloque l'accès car l'utilisateur n'appartient pas au groupe de sécurité autorisé (ex: **Domain Admins**). Le modèle en Tiers est respecté.
- **Validation Sudoers** : Une fois connecté avec un compte légitime, l'élévation de privilèges (**sudo**) est conditionnée à l'appartenance au bon groupe AD, prouvant la centralisation des droits.

3.3 Test des protections de la mémoire (Windows LSASS)

La simulation d'un vol de mot de passe en mémoire valide les défenses de bas niveau.

- **Validation RunAsPPL** : Le noyau bloque l'attachement d'un processus de débogage (ex: ProcDump) sur **lsass.exe**.
- **Validation ASR** : Le moteur Defender intercepte et bloque l'action (Event ID 1122).
- **Validation Credential Guard** : L'extraction de la mémoire, si elle réussit, ne renvoie aucun secret, ceux-ci étant confinés dans le conteneur VTL 1 de l'hyperviseur matériel.

4. Validation de la Traçabilité (Le rôle du SOC)

Toutes les actions de blocage doivent générer des alertes centralisées et inaltérables.

- L'attaquant réalise ses actions sur le serveur Windows (tentative d'exécution, requêtes réseau).
- L'agent Sysmon capte les actions, mêmes avortées.
- Le service de transfert (NXLog) convertit les journaux et les transmet en TLS vers le SIEM central (le serveur Linux).
- **Validation** : L'analyste sécurité vérifie sur le SIEM Linux que les logs Sysmon (Event ID 1 pour la création de processus, Event ID 3 pour le réseau) sont présents. Ils doivent contenir la ligne de commande exacte, l'utilisateur et le hachage de l'exécutable malveillant. Côté Linux, les journaux système (**/var/log/auth.log** ou **syslog**) tracent les échecs de connexion SSH prouvant l'efficacité de SSSD.